

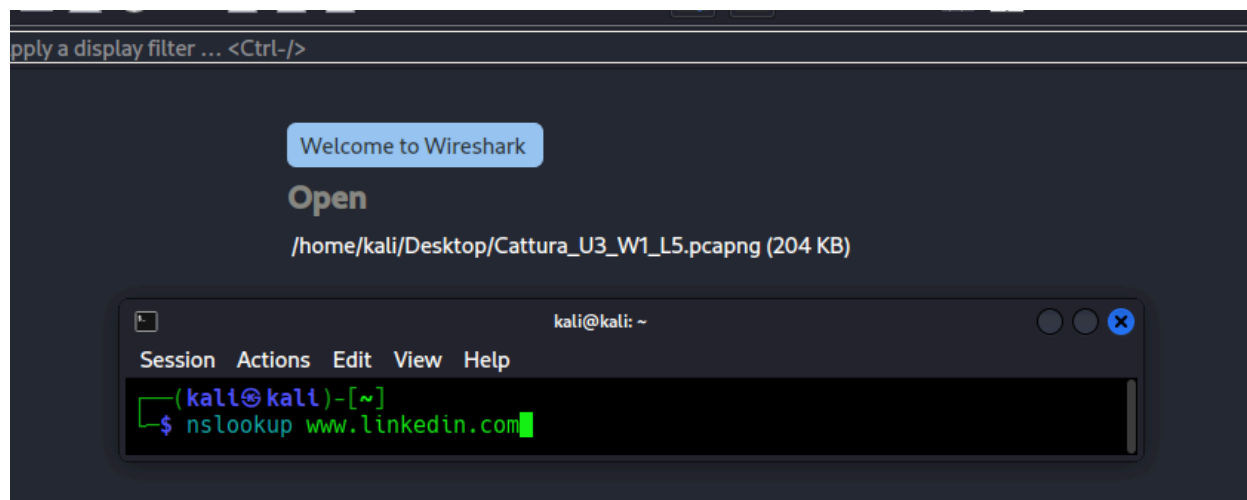
Progetto cattura DNS con Wireshark

Introduzione

Come da richiesta, oggi si procederà ad analizzare il traffico DNS di un sito, fondamentale per la sicurezza; analizzare il traffico DNS è fondamentale per capire chi, cercando un determinato dominio, interagisce con esso, ottenendo determinate chiamate alle risorse.

La macchina utilizzata in questo caso sarà Kali Linux con wireshark preinstallato.

Si procederà, tramite terminale, ad avviare il comando “nslookup” che permette di intercettare il traffico.



Per testare questo comando e fare pratica con la potenza di wireshark, si opta per il portale di linkedin.

1. Comando Nslookup

Si utilizzerà il comando Nslookup per questa operazione, come già detto.

Il funzionamento dietro questo comando è il seguente:

Uno Strumento Essenziale per l'Analisi DNS e la Mappatura di Rete

Lo strumento in questione rappresenta un elemento cardine nell'arsenale di un analista di rete o di un penetration tester, in quanto è specificamente progettato per l'interrogazione diretta e pura dei server del Domain Name System (DNS). La sua architettura operativa lo configura come un **client DNS puro**, caratteristica che ne definisce l'utilità e la potenza.

A differenza dei meccanismi di risoluzione standard integrati nei sistemi operativi (come l'utilizzo del file `/etc/hosts` o la consultazione della cache DNS locale del sistema), questo strumento è in grado di **bypassare** completamente tali livelli. Questa capacità è fondamentale perché consente all'operatore di inviare **query raw** direttamente al server DNS di destinazione specificato. Tipicamente, queste comunicazioni avvengono attraverso il protocollo **UDP sulla porta 53**, il canale standard per le query DNS, ma la flessibilità dello strumento spesso permette anche l'uso del protocollo TCP per scenari specifici, come le trasferimenti di zona (zone transfers) o quando la risposta supera i limiti di dimensione dell'UDP.

La sua funzione va ben oltre la semplice traduzione canonica di un nome a dominio (FQDN) in un indirizzo IP numerico (come un record di tipo 'A' o 'AAAA'). Grazie alla sua natura di client puro e alla possibilità di specificare vari tipi di record di query (es. NS, MX, TXT, PTR, SOA, SRV, CNAME), lo strumento si trasforma in un **vettore fondamentale per l'enumerazione e la mappatura delle infrastrutture di rete**.

Nello specifico, permette di:

1. **Indagare configurazioni DNS complesse:** Rivelando record nascosti o meno comuni che possono esporre ulteriori sottodomini, servizi e dispositivi.
2. **Verificare la coerenza e l'affidabilità dei server DNS:** Testando la latenza e l'accuratezza delle risposte da server autoritativi e ricorsivi.
3. **Identificare vulnerabilità:** Ad esempio, testando l'abilità di eseguire trasferimenti di zona (AXFR) non autorizzati, i quali possono rivelare l'intera mappa di sottodomini di un'organizzazione.
4. **Effettuare troubleshooting avanzato:** Ispezionando le risposte DNS a un livello che ignora le potenziali interferenze o i filtri del sistema operativo locale, permettendo di diagnosticare problemi di risoluzione che altrimenti resterebbero celati.

In sintesi, la sua capacità di interazione *diretta e granulare* con il protocollo DNS lo rende uno

strumento indispensabile non solo per la diagnostica di rete ma anche per la scoperta e la valutazione della superficie di attacco di un'infrastruttura.

```
(kali㉿kali)-[~]
$ nslookup www.linkedin.com
Server:      192.168.1.1
Address:     192.168.1.1#53

Non-authoritative answer:
www.linkedin.com      canonical name = cf-afd.www.linkedin.com.
cf-afd.www.linkedin.com canonical name = www.linkedin.com.cdn.cloudflare.net.
Name:   www.linkedin.com.cdn.cloudflare.net
Address: 172.64.146.215
Name:   www.linkedin.com.cdn.cloudflare.net
Address: 104.18.41.41
Name:   www.linkedin.com.cdn.cloudflare.net
Address: 2606:4700:4407::ac40:92d7
Name:   www.linkedin.com.cdn.cloudflare.net
Address: 2a06:98c1:3102::6812:2929
```

Comincia la cattura e quindi restituisce determinati risultati; nel frattempo si fa partire la cattura pacchetti con wireshark.

Wireshark restituirà la seguente cattura di pacchetti:

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	10.0.2.15	192.168.1.1	DNS	76	Standard query 0x379c A www.linkedin.com
2	0.014281905	192.168.1.1	10.0.2.15	DNS	108	Standard query response 0x379c A www.linkedin.com A 172.64.146.215 A 104.18.41.41
3	0.014987670	10.0.2.15	192.168.1.1	DNS	76	Standard query 0x5952 AAAA www.linkedin.com
4	0.033078915	192.168.1.1	10.0.2.15	DNS	202	Standard query response 0x5952 AAAA www.linkedin.com CNAME cf-afd.www.linkedin.com C
5	5.022615302	PCSSystemtec_c0:59:...	52:55:0a:00:02:02	ARP	42	Who has 10.0.2.2? Tell 10.0.2.15
6	5.023155044	52:55:0a:00:02:02	PCSSystemtec_c0:59:...	ARP	64	10.0.2.2 is at 52:55:0a:00:02:02

Viene così selezionata la porta udp 53:

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	10.0.2.15	192.168.1.1	DNS	76	Standard query 0x379c A www.linkedin.com
2	0.014281905	192.168.1.1	10.0.2.15	DNS	108	Standard query response 0x379c A www.linkedin.com A 172.64.146.215 A 104.18.41.41
3	0.014987670	10.0.2.15	192.168.1.1	DNS	76	Standard query 0x5952 AAAA www.linkedin.com
4	0.033078915	192.168.1.1	10.0.2.15	DNS	202	Standard query response 0x5952 AAAA www.linkedin.com CNAME cf-afd.www.linkedin.com CNAME www.linked

Una volta fatto questo, si provvede a selezionare il pacchetto con “query A”, packet detail e Ethernet II per vedere l’indirizzo MAC sorgente e di destinazione:

```

Ethernet II, Src: 52:55:0a:00:02:02 (52:55:0a:00:02:02), Dst: PCSSystemtec c0:59:da (08:00:27:c0:59:da)
  Destination: PCSSystemtec c0:59:da (08:00:27:c0:59:da)
  Source: 52:55:0a:00:02:02 (52:55:0a:00:02:02)
  Type: IPv4 (0x0800)
  [Stream index: 0]
Internet Protocol Version 4, Src: 192.168.1.1, Dst: 10.0.2.15
  0100 .... = Version: 4
  .... 0101 = Header Length: 20 bytes (5)
  Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)
  Total Length: 94
  Identification: 0x0004 (4)
  000. .... = Flags: 0x0
  ...0 0000 0000 0000 = Fragment Offset: 0
  Time to Live: 64
  Protocol: UDP (17)
  Header Checksum: 0xacd3 [validation disabled]
  [Header checksum status: Unverified]
  Source Address: 192.168.1.1
  Destination Address: 10.0.2.15
  [Stream index: 0]

```

Indirizzi MAC rilevati:

Source: 52:55:0a:00:02:02

Destination: 08:00:27:c0:59:da

Interfacce di rete:

1. 08:00: collegato ad Oracle Virtual Box
2. 52:55 richiesta intercettata dall'esterno e incapsulata al livello 2 dall'Hypervisor

Indirizzo IP che ha fatto la richiesta (quella di Kali linux):

10.0.2.15

Indirizzo IP che ha accolto la richiesta e successivamente mandato i pacchetti:

192.168.1.1

```

[Header checksum 0xacd3 (validation disabled)]
Source Address: 192.168.1.1
Destination Address: 10.0.2.15
[Stream index: 0]

```

Associazione interfaccia di rete di destinazione (kali linux):

```

: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
link/ether 08:00:27:c0:59:da brd ff:ff:ff:ff:ff:ff
inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0

```

utilizzando ip a per la conferma.

Associazione interfaccia sorgente:

```
(kali㉿kali)-[~]  
└─$ ip route  
default via 10.0.2.2 dev eth0 proto dhcp src 10.0.2.15 metric 100  
10.0.2.0/24 dev eth0 proto kernel scope link src 10.0.2.15 metric 100
```

con comando ip route

2. Espansione UDP

Vengono così richieste e individuate le porte di origine e di destinazione

Espandendo la sezione User Datagram Protocol, questo è quello che ci ci aspetta:

```
[User Datagram Protocol]  
User Datagram Protocol, Src Port: 53, Dst Port: 41804  
Source Port: 53  
Destination Port: 41804  
Length: 74  
Checksum: 0x88e6 [unverified]
```

Sorgente 53

Destinazione 41804

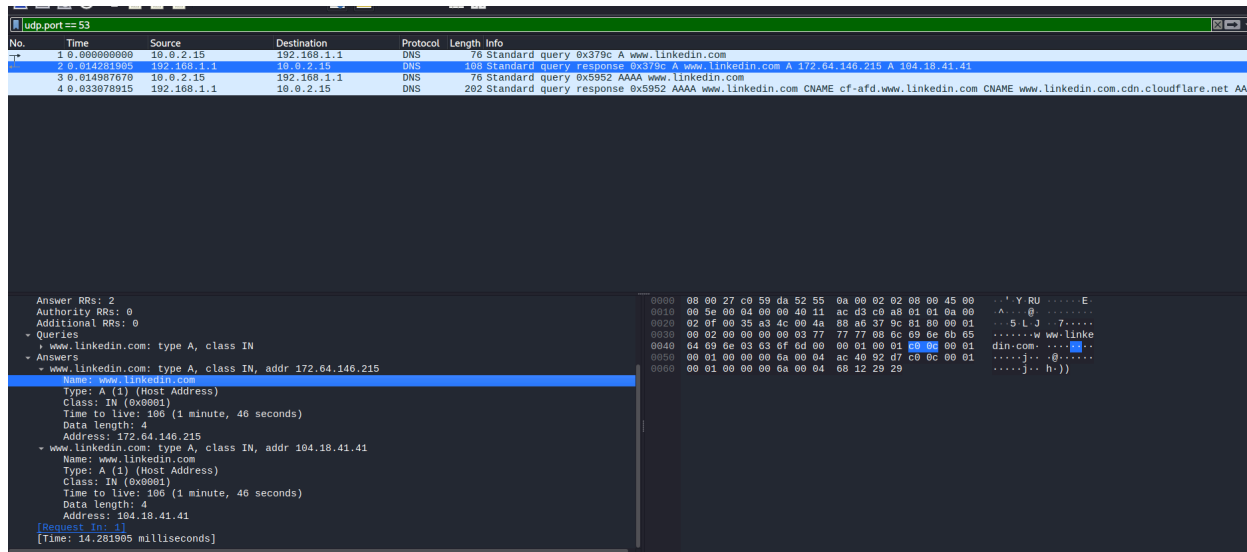
2.2 Conferma indirizzo IP

Per avere la prova che l'indirizzo IP della macchina host sia quello osservato prima, da console, si digita il comando ifconfig, e restituisce il seguente risultato:

```
(kali㉿kali)-[~]  
└─$ ifconfig  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255  
    ether 08:00:27:c0:59:da txqueuelen 1000 (Ethernet)  
    RX packets 8 bytes 1947 (1.9 KiB)
```

3. Sezione Domain Name Server System

Si procede ad espandere la finestra di domain name server system (query)



4. Conclusioni

L'applicazione del filtro `udp.port == 53` crea una visione a tunnel (tunnel vision) focalizzata esclusivamente sulla risoluzione dei nomi. Rimuovendolo, l'interfaccia viene inondata da ciò che possiamo definire l'"eco di fondo" dell'infrastruttura, svelando pattern comportamentali dell'intero segmento di rete.

Un avversario posizionato all'interno di una rete (o su un segmento Wi-Fi compromesso) può utilizzare l'intercettazione passiva per mappare e compromettere il sistema attraverso i seguenti vettori teorici:

- Estrazione di Credenziali
- Fingerprinting Architetturale
- Validazione delle Deviazioni di Flusso (MITM)